

SecureChat 安全双向通信系统实验报告

2026 年 6 月 13 日

目录

1	开发目的	2
2	系统功能	2
2.1	通信功能	2
2.2	安全功能	3
2.3	客户端和部署功能	3
3	系统设计	4
3.1	系统组成结构	4
3.2	主要数据结构	4
3.3	信令与数据通路设计	5
3.4	关键算法设计	5
3.4.1	X25519 与群密钥封装	5
3.4.2	文本和附件加密	6
3.4.3	PKI 身份签名	7
3.4.4	TLS、WSS 与 mTLS	7
4	系统实现	8
4.1	开发环境	8
4.2	系统运行截图	8
4.3	关键代码实现	9
4.3.1	Server 监听与 mTLS backend 支持	9
4.3.2	Host/Client mTLS 客户端证书配置	9
4.3.3	信令字段白名单	10
4.3.4	GKA v2 群密钥封装	11
4.3.5	应用层 encrypted relay	12

目录	2
4.3.6 PKI join_room 身份绑定	13
4.3.7 Host 拒绝身份验证失败成员	14
4.3.8 房间密码摘要保存	14
4.3.9 WinUI 调用 native core	15
4.3.10 WinUI 附件预览安全策略	16
4.4 阶段十安全测试设计	17
5 项目开发总结	18
5.1 完成情况	18
5.2 当前系统缺陷和改进方向	19
5.3 对 Host 不可信场景的讨论	19
6 心得体会	20
7 参考文献	20

1 开发目的

本项目的开发目的，是设计并实现一个安全的双向通信工具。系统需要支持局域网和公网环境中的文本、图片、语音和文件通信，并尽可能降低不可信服务器、网络监听者和主动中间人对通信内容的威胁。

在传统客户端到服务器聊天模型中，服务器通常能够接触消息明文。SecureChat 的设计目标不是让服务器成为可信聊天成员，而是让服务器只承担房间注册、成员状态维护和密文转发职责。真正的聊天内容在成员端加密和解密，服务器只看到有限元数据和密文。

本项目重点解决以下问题：

1. 实现 Server、Host、Client 三角色分离，使 Server 不参与聊天语义，不创建群密钥，也不成为房间成员。
2. 使用端到端加密（End-to-End Encryption, E2EE）保护文本和附件内容。
3. 使用群组密钥协商（Group Key Agreement, GKA）模型，为房间成员分发对称群密钥。
4. 使用公钥基础设施（Public Key Infrastructure, PKI）成员身份认证，绑定成员身份和临时 X25519 公钥，降低主动中间人替换公钥的风险。
5. 支持传输层安全（Transport Layer Security, TLS）和可选双向传输层安全（mutual TLS, mTLS）部署，保护信令入口和连接准入。
6. 明确系统的安全边界：内容机密性、元数据可见性、恶意成员限制、附件本地缓存风险等。

因此，本系统不是单纯的聊天界面实验，而是围绕“安全的网络双向通信软件”进行的协议、工程和安全测试综合设计。

2 系统功能

SecureChat 当前实现的主要功能如下。

2.1 通信功能

- Host 创建房间，Client 加入房间。
- 同一个 Server 可以承载多个不同 roomId，同一 Server 内 roomId 不允许重复。
- 支持群发文本消息。

- 支持私发文本消息，发送目标可以是成员名或成员 id。
- 支持图片、语音和普通文件附件。
- 支持私发图片、语音和文件附件。
- 成员列表显示 name / id，便于选择私发目标。
- WinUI 成员列表支持在当前房间内手动标记可信成员，用于附件自动预览策略。

2.2 安全功能

- 房间密码不再通过命令行参数传递，支持隐藏输入、标准输入管道和短生命周期环境变量。
- Server 只保存房间密码摘要，不保存房间密码明文。
- 文本和附件均通过 WebSocket encrypted relay 转发，Server 不解密应用层内容。
- GKA v2 使用临时 X25519 公钥和 Host 分发的 room group key。
- 成员加入或离开时，Host 轮换 room group key。
- PKI 成员身份认证可以绑定 Client 的 join_room 公钥和 Host 的 group_key envelope。
- WSS (WebSocket Secure) 支持服务器证书和 TLS 加密。
- mTLS 通过 Nginx 反向代理实现客户端证书准入。
- 附件具有扩展名、文件头、大小、文件名净化和缓存上限检查。
- WinUI 默认不自动预览未知成员附件，图片和音频需先显示为附件卡片。

2.3 客户端和部署功能

- 提供 C++ 命令行 Server、Host、Client。
- 提供 Windows WinUI 桌面客户端。
- 提供 ASP.NET Core Web UI。
- 提供 Windows 构建脚本 build.bat、build_win.bat、build_web.bat。
- 提供 Linux 构建脚本 build.sh、build_web.sh。
- 提供 start_server.sh、start_host.sh、start_client.sh 及对应 stop 脚本。
- 提供可选 systemd 服务模板和 Nginx mTLS 反向代理模板。

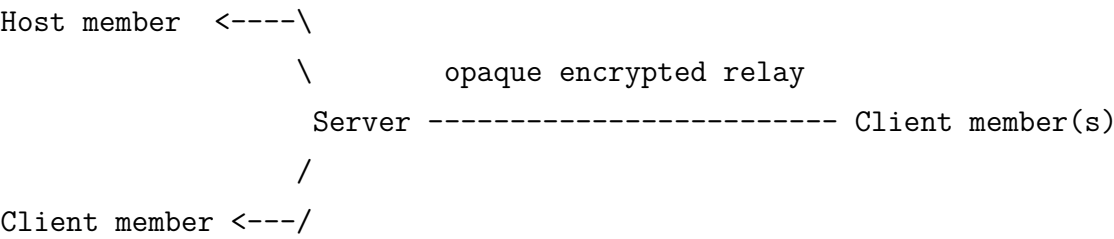
3 系统设计

3.1 系统组成结构

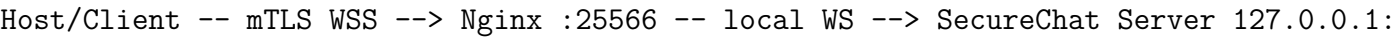
系统由三个协议角色和多个界面形态组成。

角色或组件	职责
Server	监听 WebSocket 端口，注册房间，维护成员连接状态，校验房间密码摘要，转发 encrypted relay 和 group_key envelope。Server 不是群成员，不创建群密钥，不参与密钥协商语义。
Host	创建 roomId，是第一个群成员和群管理者。Host 生成 room group key，协调 GKA v2，处理成员加入和离开时的密钥轮换。
Client	加入已有 room，生成临时 X25519 密钥对，参与 GKA v2，使用 room group key 加解密文本和附件。
WinUI	Windows 桌面图形界面，通过 native.dll 调用 C++ 核心。
Web UI	ASP.NET Core Web 界面，通过 native.dll 或 libnative.so 调用 C++ 核心，并用 Server-Sent Events 显示消息。
Nginx mTLS proxy	可选部署组件，在 TLS 握手阶段验证客户端证书，再把 WebSocket 流量转发给本机 SecureChat Server backend。

系统拓扑如下：



在 mTLS 部署中，公网入口拓扑为：



3.2 主要数据结构

系统的运行期状态由以下内存结构维护。聊天消息和附件内容不保存在 Server 端，房间状态随进程和会话生命周期存在。

数据结构	说明
------	----

UserAccount	包含 userId 和 username，表示一个登录或注册后的成员身份。
AuthService::UserRecord	保存 UserAccount 和用户密码哈希，用于同一运行期内的用户名/密码校验。
RoomRegistry::RoomState	保存 roomId、房间密码摘要、Host 成员和 Client 成员映射。
SignalingServer::ClientState	保存单个 WebSocket 对应的 roomId、clientId、userId、username、publicKey、role 和坏消息计数。
HostSessionCore	Host 本地会话状态，包括 roomId、username、Client 公钥表、当前 group key、PKI identity context 和附件接收状态。
ClientSessionCore	Client 本地会话状态，包括临时 X25519 密钥对、当前 group key、PKI identity context 和附件接收状态。
IdentityContext	保存本机成员证书链、身份私钥、信任根和本地吊销列表。

3.3 信令与数据通路设计

信令消息使用 JSON 格式。主要类型包括：

- create_room: Host 创建房间。
- join_room: Client 加入房间，提交临时 X25519 public key，并可附带 PKI identity。
- new_client: Server 通知 Host 有新 Client 加入。
- group_key: Host 为目标 Client 单独封装 room group key。
- encrypted_relay: Host/Client 之间的文本和附件密文 envelope。
- reject_client: Host 拒绝身份验证失败的 Client。

Server 对每种信令类型进行字段白名单检查和大小限制。Server 会用 WebSocket 会话状态覆盖 sender metadata，避免普通成员伪造 senderId 或跨房间注入。

3.4 关键算法设计

3.4.1 X25519 与群密钥封装

X25519 是基于 Curve25519 的 Diffie-Hellman (DH) 函数。设椭圆曲线基点为 G ，Client 生成临时私钥 c ，公钥为：

$$C = cG$$

Host 为该 Client 生成一次性封装私钥 e ，公钥为：

$$E = eG$$

双方计算共享秘密：

$$S_H = eC = ecG$$

$$S_C = cE = ceG$$

由于椭圆曲线 DH 性质，二者相等：

$$S_H = S_C$$

共享秘密不直接作为加密密钥，而是经过基于 HMAC 的密钥派生函数（HMAC-based Key Derivation Function, HKDF）派生包装密钥：

$$K_W = \text{HKDF-SHA256}(S, \text{salt} = \text{"securechat-gka-v2:"} || \text{roomId}, \text{info} = \text{"group-key"} || \text{clientId})$$

Host 生成 32 字节 room group key K_G ，再使用高级加密标准（Advanced Encryption Standard, AES）的 Galois/Counter Mode（GCM）封装：

$$(C, T) = \text{AES-256-GCM.Enc}(K_W, N, K_G, A)$$

其中 N 是随机 nonce， A 是附加认证数据（Additional Authenticated Data, AAD）。AAD 绑定 roomId 和 targetId，防止 Server 静默修改 group_key 的目标成员。

3.4.2 文本和附件加密

Host/Client 得到同一个 K_G 后，文本、图片 metadata、文件 metadata、语音 metadata 以及二进制 chunk 都使用 AES-256-GCM 加密：

$$(C, T) = \text{AES-256-GCM.Enc}(K_G, N, P, A)$$

其中 P 是明文 JSON 或附件二进制块， C 是密文， T 是认证标签。AAD 绑定 roomId、senderId、senderKind 和 targetId：

$$A = \text{"securechat-relay"} || \text{roomId} || \text{senderId} || \text{senderKind} || \text{targetId}$$

这意味着攻击者如果修改 roomId、senderId、senderKind 或 targetId，接收端重新构造 AAD 后会导致 GCM 认证失败。

3.4.3 PKI 身份签名

PKI 模式用于解决“这个临时 X25519 public key 到底属于谁”的问题。Client 在 join_room 中签名：

$$M_J = \text{roomId} || \text{username} || \text{publicKey} || \text{nonce}$$

$$\sigma_J = \text{Sign}(sk_C, M_J)$$

Host 使用成员证书中的签名公钥验证：

$$\text{Verify}(pk_C, M_J, \sigma_J) = 1$$

Host 发送 group_key envelope 时签名：

$$M_G = \text{roomId} || \text{targetId} || \text{senderId} || \text{alg} || \text{kdf} || \text{ephemeralPublicKey} || \text{nonce} || \text{ciphertext} || \text{tag} || \text{identityNo}$$

$$\sigma_G = \text{Sign}(sk_H, M_G)$$

Client 先验证 Host 证书链、吊销状态和签名，再解封装 group key。这样恶意 Server 不能静默替换 Client public key，也不能静默篡改 group_key envelope。

3.4.4 TLS、WSS 与 mTLS

WebSocket (WS) 是明文 WebSocket；WebSocket Secure (WSS) 是在 TLS 上承载 WebSocket。WSS 保护 Host/Client 到 Server 的传输层，防止被动监听者直接看到信令 JSON。

mTLS 是 mutual TLS，即 TLS 双向认证。普通 TLS 只要求 Client 验证 Server 证书；mTLS 同时要求 Server 入口验证 Client 证书。由于 libdatachannel 当前没有暴露 WebSocketServer 客户端证书校验接口，本系统使用 Nginx 在反向代理层实现 mTLS：

$$\text{Client} \xrightarrow{\text{mTLS}} \text{Nginx} \xrightarrow{\text{local WS}} \text{SecureChat Server}$$

mTLS 用于连接准入，PKI 成员身份签名用于 GKA 语义绑定，二者不是同一个安全检查点。Host/Client 通过 SECURECHAT_MTLS_CLIENT_CERT_FILE 和 SECURECHAT_MTLS_CLIENT_KEY_FILE 配置客户端证书，在 TLS 握手时出示给 Nginx。若服务器证书由私有 CA 或自签名证书签发，则额外使用 SECURECHAT_TLS_CA_FILE 指定信任根。

4 系统实现

4.1 开发环境

类别	环境
开发系统	Windows x64, PowerShell, Visual Studio 2026 Developer Command Prompt。
云部署系统	Linux x64，面向公网 Server 和 Web UI 部署。
C++ 标准	C++17。
构建系统	CMake、Ninja、vcpkg。
主要 C++ 库	libdatachannel、OpenSSL、nlohmann-json。
桌面 UI	Windows WinUI, .NET 10。
Web UI	ASP.NET Core, .NET 10, Server-Sent Events。
抓包工具	Wireshark、tcpdump。
部署工具	systemd、Nginx、Certbot 或其他 ACME 客户端。

Windows 构建命令：

```
1 build_win.bat
2 build_web.bat
```

Linux 构建命令：

```
1 ./build.sh
2 ./build_web.sh
```

4.2 系统运行截图

本节截图在提交最终报告前补充。



图 1: WinUI Host 创建房间



图 2: WinUI Client 加入房间

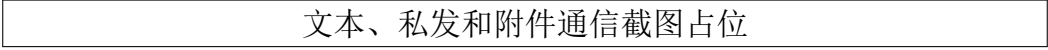


图 3: 文本、私发和附件通信

Wireshark WS/WSS/mTLS 抓包对比截图占位

图 4: Wireshark 显式安全性验证

4.3 关键代码实现

4.3.1 Server 监听与 mTLS backend 支持

以下代码展示 Server 的监听配置。普通模式监听所有网卡；mTLS 反向代理模式下设置 SECURECHAT_BIND_ADDRESS=127.0.0.1，使 SecureChat Server 只作为本机 backend 被 Nginx 访问。

Listing 1: signaling_server.cpp: Server 监听配置

```

1 SignalingServer::SignalingServer(uint16_t port) {
2     rtc::WebSocketServer::Configuration config;
3     config.port = port;
4
5     // mTLS 部署时只监听 127.0.0.1，公网入口交给 Nginx。
6     const auto bindAddress = envValue("SECURECHAT_BIND_ADDRESS");
7     config.bindAddress = bindAddress.empty() ? "0.0.0.0" : bindAddress;
8
9     // 防止半开 WebSocket 握手长期占用公网入口。
10    config.connectionTimeout = std::chrono::seconds(15);
11
12    if (envEnabled("SECURECHAT_SIGNALING_TLS")) {
13        const auto certFile = envValue("SECURECHAT_TLS_CERT_FILE");
14        const auto keyFile = envValue("SECURECHAT_TLS_KEY_FILE");
15        if (certFile.empty() || keyFile.empty()) {
16            throw std::runtime_error("TLS cert and key are required");
17        }
18        config.enableTls = true;
19        config.certificatePemFile = certFile;
20        config.keyPemFile = keyFile;
21        mUrlScheme = "wss";
22    }
23 }

```

4.3.2 Host/Client mTLS 客户端证书配置

Host/Client 使用同一段 WebSocket 客户端配置逻辑。配置 SECURECHAT_TLS_CA_FILE 可以指定自定义 CA，配置 SECURECHAT_MTLS_CLIENT_CERT_FILE 和 SE-

CURECHAT_MTLS_CLIENT_KEY_FILE 后，客户端会在 TLS 握手中出示证书。

Listing 2: websocket_config.cpp: mTLS 客户端证书配置

```

1 void applyClientTlsFromEnvironment(rtc::WebSocket::Configuration& config) {
2     const auto caFile = envValue("SECURECHAT_TLS_CA_FILE");
3     const auto certFile = envValue("SECURECHAT_MTLS_CLIENT_CERT_FILE");
4     const auto keyFile = envValue("SECURECHAT_MTLS_CLIENT_KEY_FILE");
5     const auto keyPass = envValue("SECURECHAT_MTLS_CLIENT_KEY_PASS");
6
7     if (!caFile.empty()) {
8         config.caCertificatePemFile = caFile;
9     }
10
11     if (!certFile.empty() || !keyFile.empty() || !keyPass.empty()) {
12         if (certFile.empty() || keyFile.empty()) {
13             throw std::runtime_error("mTLS client cert and key are required");
14         }
15         config.certificatePemFile = certFile;
16         config.keyPemFile = keyFile;
17         if (!keyPass.empty()) {
18             config.keyPemPass = keyPass;
19         }
20     }
21 }

```

4.3.3 信令字段白名单

Server 对每种信令消息做字段白名单和大小限制。这样未知字段不能悄悄变成协议扩展或伪造通道。

Listing 3: signaling_server.cpp: identity 字段校验

```

1 void identityField(const json& data, bool required) {
2     auto it = data.find("identity");
3     if (it == data.end()) {
4         if (required) throw std::runtime_error("missing identity");
5         return;
6     }
7     if (!it->is_object()) throw std::runtime_error("identity must be an object");
8     const auto& identity = *it;

```

```

9
10 // Server 只做结构和大小检查, 证书语义由 Host/Client 本地验证。
11 if (!hasOnlyFields(identity,
12     {"version", "certChainPem", "nonce", "signatureAlg", "signature"})) {
13     throw std::runtime_error("identity has unknown field");
14 }
15 stringField(identity, "certChainPem", maxIdentityCertChainBytes, true);
16 stringField(identity, "nonce", 64, true);
17 stringField(identity, "signatureAlg", 32, true);
18 stringField(identity, "signature", maxIdentitySignatureBytes, true);
19 }

```

4.3.4 GKA v2 群密钥封装

Host 为每个 Client 单独生成一次性 X25519 密钥对, 并派生 wrapping key 封装 room group key。

Listing 4: secure_relay.cpp: 单成员 group key 封装

```

1 json encryptGroupKeyForMember(
2     const std::vector<unsigned char>& groupKey,
3     const std::string& roomId,
4     const std::string& targetId,
5     const std::string& targetPublicKey) {
6     // Server 只转发 envelope, 不能由 targetPublicKey 推导 wrapping key。
7     const auto recipientPublic = base64Decode(targetPublicKey);
8     auto ephemeral = generateMemberKeyPair();
9     const auto secret = deriveX25519Secret(ephemeral.privateKey,
10         recipientPublic);
11     const auto wrapKey = hkdfSha256(
12         secret,
13         "securechat-gka-v2:" + roomId,
14         "group-key|" + targetId);
15     return encryptWithAesGcm(plaintext, wrapKey,
16         aadForGroupKey(roomId, targetId), {
17         {"type", GroupKeyType},
18         {"version", 2},
19         {"roomId", roomId},
20         {"targetId", targetId},
21         {"senderId", chat::protocol::HostActorId},

```

```

22         {"alg", "AES-256-GCM"},
23         {"kdf", "X25519-HKDF-SHA256"},
24         {"ephemeralPublicKey", ephemeral.publicKey}
25     });
26 }

```

4.3.5 应用层 encrypted relay

文本和附件都封装为 encrypted_relay。targetId 是明文路由字段，因此必须绑定到 AAD 中，防止恶意 Server 静默改投私发消息。

Listing 5: secure_relay.cpp: 文本和附件 relay 加密

```

1 json encryptMessageWithGroupKey(
2     const Message& message,
3     const std::string& roomId,
4     const std::string& senderId,
5     const std::string& senderName,
6     const std::string& senderKind,
7     const std::string& targetId,
8     const std::vector<unsigned char>& groupKey) {
9     // targetId 明文可见，但被 AAD 认证，不能被静默篡改。
10    const auto key = keyArrayFromVector(groupKey);
11    const auto aad = aadForEnvelope(roomId, senderId, senderKind, targetId);
12
13    return encryptWithAesGcm(message.toJson(), key, aad, {
14        {"type", EnvelopeType},
15        {"version", 2},
16        {"roomId", roomId},
17        {"senderId", senderId},
18        {"senderName", senderName},
19        {"senderKind", senderKind},
20        {"targetId", targetId},
21        {"alg", "AES-256-GCM"},
22        {"kdf", "GKA-X25519-HKDF-SHA256"}
23    });
24 }

```

4.3.6 PKI join_room 身份绑定

Client 对 roomId、username、临时 X25519 publicKey 和 nonce 签名。Host 验证证书链、吊销状态和签名后才接受该 publicKey。

Listing 6: identity_pki.cpp: join_room 签名与验证

```

1 json IdentityContext::signJoinRoom(
2     const std::string& roomId,
3     const std::string& username,
4     const std::string& publicKey) const {
5     if (!mData) throw std::runtime_error("PKI identity is not configured");
6     const auto nonce = randomNonce();
7     return makeIdentityObject(
8         mData->privateKey.get(),
9         mData->certChainPem,
10        canonicalJoinMessage(roomId, username, publicKey, nonce),
11        nonce);
12 }
13
14 void IdentityContext::verifyJoinRoom(
15     const std::string& roomId,
16     const std::string& username,
17     const std::string& publicKey,
18     const json& identity) const {
19     const auto nonce = requiredIdentityString(identity, "nonce");
20     const auto signature = base64Decode(requiredIdentityString(identity, "
        signature"));
21     const auto certs = verifiedIdentityCerts(
22         mData->trustStore.get(),
23         mData->revokedFingerprints,
24         identity);
25
26     EvpPkeyPtr publicSigningKey(X509_get_pubkey(certs.front().get()),
        EVP_PKEY_free);
27     requireSignatureAlgorithmMatches(publicSigningKey.get(), identity);
28
29     if (!verifyBytes(publicSigningKey.get(),
30         canonicalJoinMessage(roomId, username, publicKey, nonce),
31         signature)) {
32         throw std::runtime_error("join_room identity signature verification

```

```

33         failed");
34     }
}

```

4.3.7 Host 拒绝身份验证失败成员

Host 发现成员身份验证失败时，不记录该成员 publicKey，也不轮换 group key，而是请求 Server 移除该 Client。

Listing 7: host_session_core.cpp: Host 验证并拒绝 Client

```

1  if (!clientId.empty() && mIdentity.enabled()) {
2      try {
3          auto identity = j.find("identity");
4          if (identity == j.end()) throw std::runtime_error("client identity is
           missing");
5          mIdentity.verifyJoinRoom(mRoomId, username, publicKey, *identity);
6          chatEmit(mCallbacks.onStatus, "Client identity verified: " + username);
7      }
8      catch (const std::exception& e) {
9          chatEmit(mCallbacks.onError,
10                 "Client identity rejected: " + username + ": " + e.what());
11          rejectClient(clientId, "client identity verification failed");
12          return;
13      }
14 }

```

4.3.8 房间密码摘要保存

RoomRegistry 不保存房间密码明文，只保存带 domain separation 的 SHA-256 摘要。比较时使用常量时间比较。

Listing 8: room_registry.cpp: 房间密码摘要

```

1  std::array<unsigned char, 32> hashRoomPassword(
2      const std::string& roomId,
3      const std::string& password) {
4      // 只保存摘要，避免房间密码作为长生命周期明文留在 Server 内存中。
5      std::array<unsigned char, 32> digest{};
6      EVP_DigestInit_ex(ctx.get(), EVP_sha256(), nullptr);
7      EVP_DigestUpdate(ctx.get(), "securechat-room-v1", 18);
8      EVP_DigestUpdate(ctx.get(), roomId.data(), roomId.size());

```

```

9     EVP_DigestUpdate(ctx.get(), password.data(), password.size());
10    EVP_DigestFinal_ex(ctx.get(), digest.data(), &digestLength);
11    return digest;
12 }
13
14 bool RoomRegistry::passwordMatches(
15     const std::string& roomId,
16     const std::string& password) const {
17     const auto suppliedHash = hashRoomPassword(roomId, password);
18     return CRYPTO_memcmp(
19         storedHash.data(),
20         suppliedHash.data(),
21         storedHash.size()) == 0;
22 }

```

4.3.9 WinUI 调用 native core

WinUI 不直接实现密码协议，而是调用 native.dll 中的 C++ 核心。这样可以让 CLI、WinUI 和 Web UI 共用一套安全实现。

Listing 9: MainWindow.xaml.cs: Host 和 Join 入口

```

1 private void Host_Click(object sender, RoutedEventArgs e)
2 {
3     // Host 是可见群成员；独立 Server 负责监听和 TLS。
4     var ok = NativeMethods.chat_host_start(
5         HostServerUrlBox.Text.Trim(),
6         HostRoomBox.Text.Trim(),
7         HostUserBox.Text.Trim(),
8         HostPasswordBox.Password);
9     if (ok != 0) {
10         SetSessionMode(SessionMode.Host);
11     }
12 }
13
14 private void Join_Click(object sender, RoutedEventArgs e)
15 {
16     var ok = NativeMethods.chat_join_start(
17         JoinUrlBox.Text.Trim(),
18         JoinRoomBox.Text.Trim(),
19         JoinUserBox.Text.Trim(),

```



```

20     JoinPasswordBox.Password);
21     if (ok != 0) {
22         SetSessionMode(SessionMode.Join);
23     }
24 }

```

4.3.10 WinUI 附件预览安全策略

WinUI 中的“可信成员”不是 PKI 认证结果，而是用户在当前房间手动标记的临时 UI 状态。默认所有远端成员都是未知成员；未知成员发来的图片和音频先显示“附件已接收”，用户点击预览后才触发本地图片或音频解码器。自己本地选择并发送的附件按本地文件处理，但不证明该成员在密码学意义上可信。

Listing 10: MainWindow.xaml.cs: 附件预览策略

```

1 // These caps only protect local WinUI preview/decoder paths.
2 // The protocol transfer limit remains SECURECHAT_ATTACHMENT_MAX_BYTES.
3 private const long MaxPreviewImageBytes = 15L * 1024 * 1024;
4 private const long MaxPreviewAudioBytes = 50L * 1024 * 1024;
5 private const int MaxPreviewImageDimension = 8192;
6 private const long MaxPreviewImagePixels = 24_000_000;
7 private const double MaxPreviewAudioSeconds = 600;
8
9 private bool ShouldAutoPreviewAttachment(AttachmentPreviewInfo info)
10 {
11     if (info.Kind == "file") return false;
12     if (onlyTrustedAttachmentPreview &&
13         !info.IsOwnLocalAttachment &&
14         !info.IsTrustedMember) {
15         return false;
16     }
17     return info.Kind == "image" ? autoPreviewImages : autoLoadAudio;
18 }
19
20 private void ToggleTrustedParticipant(string participant)
21 {
22     // The trust mark is in-memory room state. It is cleared when the room
23     // stops, disconnects, or switches.
24     var keys = ParticipantTrustKeys(participant).ToList();
25     if (keys.Any(key => trustedAttachmentMembers.Contains(key))) {
26         foreach (var key in keys) trustedAttachmentMembers.Remove(key);

```

```
27     } else {
28         foreach (var key in keys) trustedAttachmentMembers.Add(key);
29     }
30     RefreshParticipants();
31 }
32
33 private void ValidateImagePreview(string path, long sizeBytes)
34 {
35     if (sizeBytes > MaxPreviewImageBytes) {
36         throw new InvalidDataException("image is too large for inline preview")
37         ;
38     }
39     var image = ReadImagePreviewInfo(path);
40     if (image.Width > MaxPreviewImageDimension ||
41         image.Height > MaxPreviewImageDimension ||
42         (long)image.Width * image.Height > MaxPreviewImagePixels) {
43         throw new InvalidDataException("image exceeds preview limit");
44     }
45 }
46
47 private void ValidateWavPreview(string path, long sizeBytes)
48 {
49     if (sizeBytes > MaxPreviewAudioBytes) {
50         throw new InvalidDataException("audio is too large for inline preview")
51         ;
52     }
53     var wav = ReadWavPreviewInfo(path);
54     if (wav.Channels is not (1 or 2) ||
55         wav.SampleRate < 8000 || wav.SampleRate > 192000 ||
56         wav.DurationSeconds > MaxPreviewAudioSeconds) {
57         throw new InvalidDataException("unsupported WAV preview parameters");
58     }
59 }
```

4.4 阶段十安全测试设计

阶段十的测试分为本机可完成测试和需要服务器/抓包工具手动完成的测试。

测试项	预期现象	状态
build_win.bat	C++、native.dll、WinUI 构建通过，无错误。	已完成。
build_web.bat	Web UI 和 native core 构建通过，无错误。	已完成。
旧连接层扫描	不存在 Host/Client DataChannel 建连逻辑；STUN/ICE 只在已移除语境出现。	已完成。
WS 抓包	可见 join_room 和房间密码，但不可见聊天明文和附件内容。	手动执行。
WSS 抓包	只能看到 TLS record 和元数据，不能看到 WebSocket JSON。	手动执行。
mTLS 准入	无客户端证书连接失败，有受信任证书连接成功。	手动执行。
PKI publicKey 替换	未启用 PKI 可演示攻击；启用 PKI 后 Host 拒绝。	手动执行。
附件安全	伪装文件、超大文件和路径穿越文件名被拒绝或净化。	手动执行。

详细步骤已经整理在 phase10-security-tests.md 中。需要服务器和 Wireshark 的实验保留为手动步骤，是因为它们依赖真实网卡、云安全组、Nginx 证书和抓包截图。

5 项目开发总结

5.1 完成情况

本项目已经完成了从“Host 同时承担信令服务”到“Server/Host/Client 三角色分离”的重构。当前 Server 是不可信信令协调者和密文 relay，不是聊天成员。Host 是第一个群成员和群管理者，Client 是普通成员，二者都使用 room group key 加解密文本和附件。

当前主要安全成果包括：

- 移除 WebRTC/DataChannel 数据通路，统一为 TCP WebSocket encrypted relay。
- 实现 GKA v2: Client 临时 X25519 public key，Host 分发 room group key。

- 实现成员加入/离开后的 group key rotation。
- 实现文本、图片、语音、文件 metadata 和 binary chunk 的 AES-256-GCM 加密。
- 实现 PKI 成员身份认证，绑定 join_room publicKey 和 group_key envelope。
- 实现本地证书指纹吊销列表。
- 实现 WSS 和 mTLS 反向代理部署路径。
- 完成 WinUI 和 Web UI 的基本可用界面。

5.2 当前系统缺陷和改进方向

当前系统仍有一些重要限制。

第一，当前私发是 group key 下的定向投递，而不是独立点对点私聊密钥。Server 只把密文投递给目标成员，但同一房间的其他合法成员理论上仍持有相同 K_G 。如果恶意 Server 复制私发密文给其他成员，其他成员可能具备解密能力。后续可以加入 pairwise key 或 sender key，为私发消息建立独立密钥。

第二，Host 在当前 GKA v2 中仍是密钥协调者。如果 Host 不可信，Host 可以生成、轮换和分发 room group key，因此 Host 在协议中拥有较强权限。要在 Host 不可信场景下提升安全性，需要更复杂的多方 GKA 或 Messaging Layer Security (MLS) 一类协议，让群密钥由多方共同贡献，而不是由 Host 单方生成。

第三，Server 仍能观察元数据，包括 roomId、成员在线状态、消息大小、发送频率和转发时序。E2EE 保护内容机密性，但不隐藏通信模式。后续可以考虑 padding、批量发送或混淆转发时序，但会增加带宽和延迟成本。

第四，附件安全仍不等于恶意文件防护。当前系统能检查大小、扩展名、文件头、文件名和缓存目录，WinUI 也默认不自动预览未知成员附件，并在预览前检查图片尺寸、像素数和 WAV 结构；但这些措施不能替代杀毒、沙箱和复杂文档解析隔离。

第五，当前 PKI 吊销使用本地受信任指纹列表。它简单可复现，但不是完整在线证书状态协议 (Online Certificate Status Protocol, OCSP) 或证书吊销列表 (Certificate Revocation List, CRL) 体系。正式部署可进一步接入自动化证书签发、吊销分发和密钥轮换流程。

5.3 对 Host 不可信场景的讨论

如果 Host 不可信，当前系统不能保证 Host 不读取或不操纵群密钥。原因是 Host 是 GKA v2 的协调者，负责生成 K_G 并为每个 Client 封装。PKI 可以证明“某个 public key 属于某个成员身份”，mTLS 可以限制“谁能连接入口”，但二者都不能改变 Host 在密钥分发中的权限。

若要对不可信 Host 建立更强安全性，可以考虑：

- 多方 DH 或树形群密钥协商，使每个成员都贡献密钥材料。
- MLS 协议，使用 TreeKEM 等机制管理群成员变更。
- 私发采用独立 pairwise key，避免 Host 或其他成员共享私发密钥。
- 增加透明日志或成员可验证的密钥变更记录，降低 Host 静默作恶空间。

6 心得体会

通过本项目可以看到，安全通信软件的难点不仅是“把消息加密”，更是把系统边界讲清楚并落到代码中。最初如果 Host 同时承担信令服务和聊天成员职责，系统很容易在概念上混淆：到底谁可信、谁能看明文、谁负责密钥协商，都不够清晰。将 Server、Host、Client 拆开后，安全模型才变得可解释。

另一个体会是，TLS、mTLS、PKI 和 E2EE 分别解决不同问题。TLS 保护传输通道，mTLS 做连接准入，PKI 身份签名绑定成员身份和临时公钥，E2EE 保护应用内容。它们可以叠加，但不能互相替代。设计安全系统时，如果把这些概念混在一起，就很容易产生“用了 TLS 就等于端到端加密”之类的错误判断。

本项目也体现了工程取舍的重要性。例如 libdatachannel 已经提供 WebSocket 和 TLS 能力，但没有直接暴露服务端客户端证书验证接口。强行修改底层库成本较高，使用 Nginx 做 mTLS 反向代理则更稳定、更容易部署和测试。这说明安全工程中并不总是要把所有能力都塞进应用进程，清晰的分层往往更可靠。

最后，安全测试同样重要。Wireshark 抓包可以直观看到 WS 明文信令与 WSS/mTLS 加密传输的区别；public key 替换挑战可以说明为什么 X25519 本身不提供身份认证；附件伪装和路径穿越测试可以提醒我们文件安全不是单一加密算法能解决的问题。这些实验能帮助系统从“功能可用”走向“安全边界可证明”。

7 参考文献

参考文献

- [1] I. Fette and A. Melnikov. The WebSocket Protocol. RFC 6455, 2011.
- [2] E. Rescorla. The Transport Layer Security (TLS) Protocol Version 1.3. RFC 8446, 2018.
- [3] A. Langley, M. Hamburg, and S. Turner. Elliptic Curves for Security. RFC 7748, 2016.

- [4] H. Krawczyk and P. Eronen. HMAC-based Extract-and-Expand Key Derivation Function (HKDF). RFC 5869, 2010.
- [5] National Institute of Standards and Technology. Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC. NIST SP 800-38D, 2007.
- [6] OpenSSL Project. OpenSSL Documentation. <https://www.openssl.org/docs/>
- [7] Nginx. Module ngx_http_ssl_module Documentation. https://nginx.org/en/docs/http/ngx_http_ssl_module.html
- [8] libdatachannel Project. C/C++ WebRTC network library. <https://github.com/paullouisageneau/libdatachannel>
- [9] R. Barnes, B. Beurdouche, R. Robert, J. Millican, E. Omara, and K. Cohn-Gordon. The Messaging Layer Security (MLS) Protocol. RFC 9420, 2023.